COMPANION DOCUMENT TO THE AI RISK ASSESSMENT WORKBOOK

AI Risk Mitigation Strategies Guide

Best Practices, Frameworks & Real-World Examples

Evolve Edge · Enterprise AI Governance Framework · Version 1.0

Classification: Confidential · Review Annually

Practical · Actionable · Evidence-Based

© 2025 Evolve Edge | All Rights Reserved

TABLE OF CONTENTS

1.	Introduction & Purpose	3
2.	AI Risk Categories	3
3.	Mitigation Strategies by Risk Level	4
3.1	Low Risk Strategies	4
3.2	Medium Risk Strategies	4
3.3	High Risk Strategies	5
4.	Technical Safeguard Controls	5
5.	Governance & Organisational Controls	6
6.	Real-World Examples & Case Studies	6
7.	Mitigation Planning Template	7
8.	Best Practice Checklist	8

© 2025 Evolve Edge | All Rights Reserved

1. Introduction & Purpose

This guide is designed to complement the **Evolve Edge AI Risk Assessment Workbook**. Whereas the Workbook helps you identify and score risks, this Guide provides actionable mitigation strategies, proven frameworks, and real-world examples to help you reduce those risks to an acceptable residual level.

Effective AI risk mitigation is not a one-time activity. It requires continuous monitoring, regular review cycles, and an organisational culture that treats AI governance as a core business priority. This guide applies to all AI systems regardless of vendor, architecture, or deployment model.

2. AI Risk Categories

Category	Description	Examples
Bias & Fairness	Systematic discrimination in outputs affecting protected groups	Resume screener rejecting female applicants; facial recognition errors
Data Privacy	Unauthorised exposure or misuse of personal or sensitive data	LLM memorising PII; model inversion attacks revealing training data
Model Robustness	Failures under adversarial inputs, edge cases, or distribution shifts	Autonomous vehicle misclassifying road signs; fraud model evaded by new patterns
Explainability	Inability to explain or justify AI decisions to affected parties	Black-box credit refusal; opaque medical diagnosis recommendation
Operational	System failures, downtime, or performance degradation	Chatbot generating harmful content; prediction API returning stale data
Legal & Compliance	Breach of regulatory requirements (GDPR, EU AI Act, sector rules)	High-risk AI deployed without conformity assessment; unlawful profiling
Cybersecurity	Attacks targeting AI models, training pipelines, or inference endpoints	Prompt injection; model poisoning; adversarial examples in production
Third-Party / Supply Chain	Risks inherited from vendors, open-source models, or data providers	Vulnerable open-source library; biased third-party training dataset

© 2025 Evolve Edge | All Rights Reserved

3. Mitigation Strategies by Risk Level

3.1 Low Risk Strategies (Score 1–4)

Strategy	Implementation	Frequency
Annual Monitoring	Review system outputs quarterly; log anomalies	Annual review
Basic Documentation	Maintain system card; record training data sources	At deployment
User Awareness	Brief end-users on system limitations and failure modes	Onboarding
Vendor SLA Review	Confirm vendor uptime SLA and incident response terms	Annual
Lightweight Testing	Functional regression tests before updates	Per release

3.2 Medium Risk Strategies (Score 5–12)

Strategy	Implementation	Frequency
Bias Audit	Run fairness metrics across demographic groups; document findings	Quarterly
Explainability Layer	Implement SHAP/LIME or equivalent; produce decision logs	Continuous
Data Governance	Define data lineage; implement access controls; retention policy	Ongoing
Human-in-the-Loop	Flag edge cases to human reviewers before actioning	Continuous
Incident Response Plan	Document escalation path for model errors or failures	Annual test
Third-Party Assessment	Engage independent expert to validate risk scores	Bi-annual

© 2025 Evolve Edge | All Rights Reserved

3.3 High Risk Strategies (Score 13–25)

Strategy	Implementation	Frequency
Formal Risk Assessment	Full EU AI Act / ISO 42001 conformity assessment before deployment	Pre-deployment
Continuous Monitoring	Real-time dashboards; automated drift & anomaly detection	24/7
Adversarial Testing	Red-team exercises; penetration testing of model endpoints	Quarterly
Data Minimisation	Use synthetic data; apply differential privacy techniques	By design
Ethics Review Board	Mandatory sign-off from ethics committee before launch	Pre-deployment
Regulatory Notification	Notify relevant authority (e.g. ICO) of high-risk AI deployment	At deployment
Kill-Switch Protocol	Documented & tested procedure to halt AI system immediately	Tested quarterly

4. Technical Safeguard Controls

Model Development Controls:

- Version control all model artefacts (Git + DVC)
- Train/test split with stratification for fairness
- Cross-validation & holdout set evaluation
- Document training data sources and preprocessing
- Apply regularisation to reduce overfitting

Deployment Controls:

- Canary / staged rollout (1% → 10% → 100%)
- Feature flags to disable model components
- API rate limiting & authentication
- Model output validation and bounds checking

Monitoring & Observability:

- Track data drift with Population Stability Index
- Monitor prediction distributions over time
- Alert on accuracy / F1 degradation > threshold
- Log all model inputs/outputs (with PII masking)

Security Controls:

- Encrypt model weights at rest and in transit
- Input sanitisation to prevent prompt injection
- Isolate model inference environments
- Regular dependency vulnerability scanning

© 2025 Evolve Edge | All Rights Reserved

5. Governance & Organ

Control	Description	Owner	Evidence
	d n	Select...	
	ic n-	Select...	
	A g	Select...	
	qu no	Select...	
DPIA Integration	Data Protection Impact Assessment linked to AI assessment	DPO	DPIA report
Cha		Select...	
Wh	er	Select...	
		Select...	

LOW RISK CASE: Customer Service Chatbot — Retail Company

Risk: Chatbot occasionally misunde
Mitigation: Implemented intent confid
audit of misclassified intents. Outcom

Select...

MEDIUM RISK CASE: Credit Sco

Risk: Model showed 12% disparity in approval rates between demographic groups (score: 9 – Medium).
Mitigation: Re-weighted training data
added human review for borderline cases. Outcome: Disparity reduced to <2%; full FCA compliance maintained.

HIGH RISK CASE: AI-Assisted Medical Diagnosis — Healthcare Provider

Risk: Model used in triage with high impact on patient outcomes (score: 20 – High).
Mitigation: Full clinical validation study; mandatory radiologist sign-off for all AI flags; real-time drift monitoring with 24h alert SLA; ethics board review; MHRA registration. Outcome: 15% improvement in early detection; zero adverse incidents in 18 months.

© 2025 Evolve Edge | All Rights Reserved

7. Mitigation Planning Template

Use this template for each AI system to plan, track, and evidence your mitigation activities. Complete one template per system and attach to the AI Risk Assessment Workbook.

System Details

AI System Name	
Risk Score (L × I)	
Risk Category	
Risk Owner	

Identified Risks

	Risk Description	Category	Score
1			
2			

Mitigation Actions

Action	Responsible	Target Date	Status	Evidence

Residual Risk After Mitigation	
Sign-off Approver & Date	

© 2025 Evolve Edge | All Rights Reserved

8. Best Practice Checklist

Use this checklist to verify your organisation's AI risk management maturity. Tick each item once fully evidenced. Target: all items checked before high-risk AI deployment.

Governance & Strategy

- ☐ AI governance policy is documented, approved, and communicated organisation-wide
- ☐ An AI ethics or risk committee exists with defined terms of reference
- ☐ All AI projects are formally registered in an AI system inventory
- ☐ Roles and responsibilities for AI risk are clearly defined
- ☐ AI risk is formally included on the enterprise risk register

Risk Assessment

- ☐ Risk Assessment Workbook completed for every AI system before deployment
- ☐ Likelihood and impact scores are validated by more than one reviewer
- ☐ Risk scores are linked to specific mitigation actions with owners and dates
- ☐ High-risk systems have undergone formal independent review
- ☐ Risk assessments are reviewed quarterly or after significant model changes

Technical Safeguards

- ☐ Model version control and reproducibility standards are in place
- ☐ Automated drift and anomaly monitoring is active in production
- ☐ Bias evaluation metrics are defined and tracked for each AI system
- ☐ Security controls (encryption, access control, pen testing) are implemented
- ☐ A tested kill-switch or rollback procedure exists for each AI system

Human Oversight

- ☐ Human-in-the-loop requirements are defined for high-risk decisions
- ☐ End users are trained on AI system limitations and failure modes
- ☐ Appeals/redress mechanisms exist for AI-affected individuals
- ☐ Escalation paths are documented and tested for model failures
- ☐ Ethics concerns can be raised safely via a whistleblower channel

Maturity Scoring: *Count checked items:* ***0–10*** *= Initial ·* ***11–15*** *= Developing ·* ***16–18*** *= Defined ·* ***19–20*** *= Optimised*

© 2025 Evolve Edge | All Rights Reserved